DuocUC | ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

CUIDARTE+

EVALUACIÓN PARCIAL N° 3

Verificación de calidad, seguridad y cumplimiento normativo

Informe de seguridad y calidad en el desarrollo de software

Caso B: Sistema de exámenes médicos Cuidarte+

Asignatura
ISY1102 · Seguridad y Calidad en el Desarrollo de Software

Carrera: Ingeniería en Informática
Sección: 001V
Sede: Puente Alto
Docente: Jose Sergio Collio Huennun
Fecha: Octubre de 2026

Integrantes
Ari Araya
Nicolás Barra
Giannina Guerrero
Skarlett Tropan

ÍNDICE

1. Introducción..... 3
2. Criterios de calidad..... 4
3. Plan de pruebas..... 6
3.1 Estrategia de pruebas..... 6
3.2 Tipos de prueba..... 8
3.3 Criterios de aceptación..... 9
3.4 Herramientas utilizadas..... 10
4. Diseño de casos de prueba..... 12
5. Ejecución de pruebas..... 23
5.1 Resumen de ejecución..... 23
5.2 Detalle de ejecución de casos..... 24
5.3 Criticidad de incidentes..... 25
5.4 Análisis estático con SonarQube..... 27
6. Análisis ético y normativo de los resultados..... 28
7. Conclusiones..... 32
8. Referencias..... 33
Anexo A. Correcciones respecto de la EV1..... 33
Anexo B. Evidencias de la EV1 reutilizadas..... 34

*Nota de avance: las marcas **«[Pendiente: …]»** indican contenido que depende de la ejecución de las pruebas y que se completa antes de la entrega.*

1. Introducción

1.1 Contexto del software

Cuidarte+ es una plataforma web para centros de salud desarrollada por CreaLab SpA y corresponde al Caso B de la asignatura. Permite que los médicos registren pacientes y exámenes, que los pacientes revisen y descarguen sus documentos clínicos y que los administradores gestionen usuarios y revisen la auditoría. Está construida como una SPA en React que consume una API REST en Express sobre una base de datos PostgreSQL. Para esta evaluación se ejecuta en contenedores Docker en los equipos del grupo: el frontend en el puerto 3333, la API en el 4444 (con la documentación Swagger en /docs) y la base de datos en el 15442.

El sistema trata datos de salud, que la legislación chilena califica como datos sensibles, y su público incluye personas mayores. Por eso un defecto en Cuidarte+ no queda solo en el plano técnico: puede afectar la confidencialidad de la ficha clínica, la continuidad de la atención y la responsabilidad legal del centro que lo utilice.

1.2 Propósito del plan y de este informe

En la primera evaluación parcial (EV1) diseñamos el plan de pruebas y seis casos representativos. Este informe continúa ese trabajo con tres cambios. Primero, la cobertura pasa de 14 a los 40 códigos del ERS B, cada uno con su caso de prueba. Segundo, los casos se ejecutan en el ambiente Docker y se registran con evidencia, resultado e incidentes clasificados por criticidad. Tercero, el análisis normativo incorpora la normativa sanitaria que faltaba en la EV1 (derechos de los pacientes, ficha clínica y atención de urgencia) y separa las normas vigentes de las que entran en vigencia más adelante. Estos ajustes responden a la retroalimentación que recibimos del docente sobre la EV1, y su detalle está en el Anexo A.

Las pruebas buscan asegurar tres cosas antes de un paso a producción: que el sistema hace lo que el ERS describe, que lo hace de forma segura con los datos clínicos y que permite al centro de salud cumplir la ley que lo regula.

1.3 Objetivos

Objetivo general. Verificar si Cuidarte+ cumple los requisitos funcionales, no funcionales y reglas de negocio del ERS B, junto con las exigencias legales que aplican a un sistema que gestiona información clínica, para emitir un dictamen fundado sobre su aptitud para producción.

Objetivos específicos. Para lograrlo nos planteamos los siguientes objetivos específicos:

1. Asociar cada uno de los 40 códigos del ERS B a un caso de prueba con tipo, riesgo y responsable definidos.
2. Ejecutar los casos en el ambiente Docker y registrar resultado, evidencia, fecha y responsable.
3. Clasificar los incidentes encontrados según la escala de criticidad de la sección 5.3.
4. Contrastar los resultados del análisis estático (SonarQube) y de las pruebas dinámicas con la normativa de la sección 6.
5. Proponer recomendaciones priorizadas y un dictamen de certificación.

1.4 Alcance

Quedan dentro del alcance todos los módulos del ERS B: autenticación y sesión, registro de usuarios, gestión de pacientes, exámenes y documentos, visualización por parte del paciente, auditoría y administración de usuarios y roles, además de los atributos de seguridad, rendimiento, usabilidad, disponibilidad y compatibilidad. Las pruebas se hacen solo sobre la instalación local en Docker y con datos sintéticos. Quedan fuera un pentest certificado por terceros, la certificación formal WCAG, una auditoría legal externa y la medición de disponibilidad durante un mes completo; para NFR-DIS-1 se revisa la configuración y la documentación, no el uptime real.

El ERS B conserva algunos restos del Caso A: el glosario define Atlas y el rol Editor, la sección 2.3 indica que cada usuario debe pertenecer a una o más empresas, RF-5.1 menciona clientes y contratos, y NFR-SEG-1 escribe TSL en lugar de TLS. En este informe esos requisitos se interpretan sobre las entidades reales de Cuidarte+ (pacientes, exámenes, documentos y usuarios) y se escribe TLS.

1.5 Estructura del informe

El informe sigue el formato de la EP3. La sección 2 define los criterios de calidad, seguridad y cumplimiento; la sección 3 presenta el plan de pruebas (estrategia, tipos de prueba, criterios de aceptación y herramientas); la sección 4 contiene la matriz de trazabilidad y el diseño de los casos; la sección 5 muestra la ejecución, con el resumen, el detalle por caso, la criticidad de los incidentes y el análisis estático; la sección 6 desarrolla el análisis ético y normativo de los resultados, y la sección 7 cierra con las conclusiones. Al final se incluyen las correcciones respecto de la EV1 (Anexo A) y la lista de evidencias de la EV1 que se reutilizan (Anexo B).

2. Criterios de calidad

Los criterios de esta sección son el estándar contra el que se evalúa Cuidarte+. Provienen de tres fuentes: el modelo de calidad ISO/IEC 25010, los requisitos no funcionales del ERS

B y la normativa chilena que regula el tratamiento de datos de salud. Cada criterio se asocia a los códigos del ERS que lo sustentan y al caso de prueba que lo verifica.

2.1 Calidad del producto

Tabla 1. Criterios de calidad del producto (ISO/IEC 25010)

Atributo	Criterio para Cuidarte+	ERS	Casos
Usabilidad	Tipografía legible, contraste adecuado y controles grandes para personas mayores; flujos claros de registro y consulta; mensajes de error comprensibles	NFR-USAB-1 a 4	CP-06, CP-20
Rendimiento	CRUD simple bajo 300 ms (p95) con carga normal; página principal bajo 2 s en conexión móvil promedio; 200 usuarios concurrentes	NFR-PERF-1 a 3	CP-05, CP-19
Estabilidad y confiabilidad	Los flujos críticos responden sin errores 5xx con carga normal; los datos clínicos no se pierden ni se alteran entre operaciones	RF-3, RF-4, NFR-PERF-3	CP-05, CP-11, CP-13, CP-19
Disponibilidad	Objetivo de 99,5 % mensual y mantenimiento con ventana definida y migración segura de datos	NFR-DIS-1, NFR-DIS-2	CP-21
Mantenibilidad	Validación en el servidor, endpoints documentados en Swagger y código sin defectos bloqueantes en el análisis estático	ERS §3.1.2	CP-16, CP-17
Compatibilidad	Dos últimas versiones de Chrome, Firefox, Safari y Edge; diseño responsivo en móvil y tablet	NFR-COMPAT-1, 2	CP-06, CP-22

2.2 Seguridad

La seguridad se trata como un requisito verificable. Cada criterio del ERS se traduce en una condición que se puede observar en la respuesta de la API, en la base de datos o en la configuración del despliegue, y no solo en la interfaz.

Tabla 2. Criterios de seguridad

Código	Criterio	Qué se verifica	Casos
NFR-SEG-1	TLS obligatorio	El tráfico HTTP se rechaza o se redirige a HTTPS en frontend y API	CP-14
NFR-SEG-2	Hash seguro de contraseñas (bcrypt)	Las contraseñas no se guardan ni se comparan en texto plano	CP-01, CP-15
NFR-SEG-3	Cifrado en reposo	Datos clínicos y documentos protegidos en la base de datos y en el almacenamiento	CP-16
NFR-SEG-4	Control de acceso por rol en el backend	El paciente solo lee; el administrador gestiona; el médico opera según RB-3	CP-04, CP-08
NFR-SEG-5	Protección contra CSRF, XSS e inyección SQL	Entradas validadas y saneadas; cargas maliciosas rechazadas	CP-04
NFR-SEG-6	Gestión de log segura	Eventos relevantes registrados sin secretos; errores sin detalles internos	CP-17
NFR-SEG-7	Respaldo y recuperación	Respaldo definido y restauración probada	CP-18
NFR-SEG-8	Cumplimiento de protección de datos	Acceso restringido, trazabilidad y uso de datos acotado a la finalidad	CP-23 (con CP-03, CP-04)

Código	Criterio	Qué se verifica	Casos
NFR-SEG-9	Sesión con JWT	Token de vigencia acotada, cierre de sesión y revocación	CP-01, CP-07

Las reglas de negocio completan estos criterios: el paciente solo tiene permisos de lectura sobre su información (RB-1), el administrador tiene acceso completo (RB-2) y el médico puede ver la información clínica de cualquier paciente registrado (RB-3). Esta última regla presenta una tensión con la Ley 20.584 que se analiza en la sección 6.3.

2.3 Cumplimiento normativo

La normativa se desarrolla en la sección 6. Aquí se resume la relación entre los criterios transversales, los códigos del ERS y la norma que los respalda. A diferencia de la EV1, la base del caso es la normativa sanitaria (Ley 20.584 y Decreto 41 de 2012 del MINSAL), y la Ley 21.719 se cita como norma de vigencia futura (1 de diciembre de 2026).

Tabla 3. Criterio, requerimiento y norma

Criterio transversal	Códigos ERS	Norma de respaldo
Confidencialidad de la ficha clínica	NFR-SEG-3, NFR-SEG-4, RB-1	Ley 20.584 art. 13; DS 41 art. 9; Ley 19.628 art. 11
Integridad y autenticidad de los documentos	RF-4.3, RF-4.4, NFR-SEG-3	Ley 20.584 art. 12; DS 41 art. 8
Trazabilidad de accesos y cambios	RF-5.1, NFR-SEG-6	DS 41 art. 9; Ley 21.663 art. 9
Autenticación y sesión	RF-1.1, RF-1.2, NFR-SEG-2, NFR-SEG-9	Ley 19.628 art. 11; NCh-ISO 27002 como referencia técnica
Disponibilidad y acceso oportuno	NFR-DIS-1, NFR-PERF-1 a 3	Ley 20.584 arts. 10, 13 y 15 b); DS 41 art. 8
Conservación de la información clínica	RF-3.3, RF-2.7	Ley 20.584 art. 13 (15 años); DS 41 arts. 11 y 12
Accesibilidad para personas mayores	NFR-USAB-1 a 4, NFR-COMPAT-2	Ley 20.584 arts. 5 a) y 5° bis; Manual de Accesibilidad Web
Licencias de dependencias	Stack tecnológico (ERS §3.1.2)	Ley 17.336 arts. 78 y 79
Protección de datos (vigencia futura)	NFR-SEG-3, NFR-SEG-7, NFR-SEG-8	Ley 21.719, vigente desde el 01-12-2026

3. Plan de pruebas

3.1 Estrategia de pruebas

Enfoque

Usamos un enfoque mixto. Automatizamos lo que conviene repetir o medir con precisión: los flujos principales con Selenium, las pruebas de carga y de tiempo de respuesta con JMeter, el análisis dinámico con OWASP ZAP y Nikto, la búsqueda de inyección SQL con SQLMap y el análisis estático con SonarQube. Dejamos en manual lo que necesita criterio humano, como la usabilidad con personas mayores, la revisión de mensajes de error, la exploración

con Burp Suite sobre peticiones concretas y las verificaciones de configuración (TLS, cifrado y respaldo).

En un sistema clínico la interfaz no basta como evidencia. Un caso de control de acceso se verifica en la respuesta de la API y en la tabla de auditoría, no solo en lo que muestra la pantalla. Por eso varios casos funcionales incluyen también un paso de API con Postman o Swagger.

Etapas del proceso

La ejecución se organiza en cinco etapas. Como la fecha de la evaluación (D) no estaba publicada al momento de planificar, el cronograma se expresa en días antes de D.

Tabla 4. Etapas de la ejecución

Etapa	Qué se hace	Cuándo	Responsable	Termina cuando
1. Preparación	Docker en los cuatro equipos, cuentas de prueba sintéticas, SonarQube instalado	D−13	Ari (Skarlett en SonarQube)	Los tres contenedores responden y /docs abre
2. Diseño	Matriz 40/40, fichas de casos y revisión cruzada	D−12 a D−9	Giannina (matriz), Nicolás (fichas)	Ningún código del ERS sin caso
3. Ciclo 1, humo	Login de los tres roles, inicio, listado de pacientes y consulta de un examen	D−8	Nicolás	La ruta crítica funciona o queda como Bloqueado
4. Ciclo 2, ejecución completa	CP-01 a CP-23, DAST autenticado, JMeter con y sin el retraso de 5 s, SonarQube	D−8 a D−6	Nicolás, Skarlett y Ari	Registro completo con fecha, ejecutor y evidencia
5. Regresión y cierre	Reejecución de casos corregidos, clasificación de incidentes, dictamen	D−5 a D−4	Ari (criticidad), Giannina (dictamen)	Cada incidente con severidad y evidencia; dictamen escrito

Priorización

Mantenemos la priorización por riesgo de la EV1. P0 agrupa autenticación, control de acceso y documentos clínicos, donde una falla expone datos de salud. P1 cubre auditoría, registros y respaldo, que son la evidencia que el centro necesita ante un incidente. P2 es el CRUD clínico, núcleo del negocio. P3 corresponde a rendimiento y disponibilidad, que tienen umbrales numéricos en el ERS, y P4 a usabilidad y compatibilidad. Si falta tiempo, se ejecuta primero todo P0 y P1; un caso P3 o P4 sin ejecutar se informa como No ejecutado y nunca como aprobado.

Criterios de entrada

La ejecución formal comienza cuando el ambiente Docker funciona con los tres contenedores en el equipo de quien ejecuta, existen cuentas de prueba para administrador, médico y paciente con datos sintéticos, la matriz tiene los 40 códigos con caso asignado y cada caso que se va a ejecutar tiene resultado esperado y criterio de aceptación escritos.

Criterios de salida

El ciclo termina cuando todos los casos P0 y P1 tienen resultado registrado, cada falla tiene su incidente con severidad y evidencia legible, la matriz muestra los 40 códigos con estado de ejecución y el resumen de la sección 5.1 cuadra con el detalle de la sección 5.2. Terminar el ciclo no significa aprobar el sistema: si queda un incidente crítico abierto, el ciclo se cierra igual, pero el dictamen es No certificado.

Suspensión y reanudación

Si el ciclo de humo falla en el login o en la carga de la página de inicio, la ejecución se suspende y los casos dependientes se registran como Bloqueado con su causa. Se reanuda cuando el ambiente vuelve a responder; los casos ya ejecutados no se repiten, salvo que el cambio afecte su resultado.

3.2 Tipos de prueba

Las pruebas funcionales responden a la pregunta de si el sistema hace lo que debe hacer, y se derivan de RF-1 a RF-5 y de las reglas de negocio. Las no funcionales evalúan cómo lo hace: si es seguro, rápido, usable y compatible, y se derivan de los NFR. En Cuidarte+ ninguna de las dos reemplaza a la otra. Un flujo que funciona pero que entrega datos clínicos a un rol no autorizado es, además de un defecto, un incumplimiento de la Ley 20.584.

Tabla 5. Tipos de prueba aplicados

Tipo	Propósito en Cuidarte+	Requisitos	Casos
Funcional	Verificar los flujos de negocio por rol: login, pacientes, exámenes, documentos y administración de usuarios	RF-1 a RF-4, RB-2, RB-3	CP-01, 02, 08 a 12
Integración y API	Validar los contratos entre React, Express y PostgreSQL: códigos HTTP, persistencia y almacenamiento de documentos	RF-4.4, RF-5.1, ERS §3.1.2	CP-03, CP-13
Seguridad dinámica	Detectar fallas de control de acceso, sesión, inyección y configuración con el sistema en ejecución	NFR-SEG-2, 4, 5, 9, RB-1	CP-04, 07, 15
Seguridad estática	Revisar el código fuente sin ejecutarlo para encontrar vulnerabilidades, secretos y defectos de calidad	NFR-SEG-3, NFR-SEG-6	CP-16, CP-17
Configuración y cumplimiento	Comprobar TLS, cifrado, respaldo, disponibilidad y la lista de exigencias legales	NFR-SEG-1, 7, 8, NFR-DIS-1, 2	CP-14, 18, 21, 23
Rendimiento y carga	Medir tiempos de respuesta y concurrencia frente a los umbrales del ERS	NFR-PERF-1 a 3, RF-4.2	CP-05, CP-13, CP-19
Usabilidad y accesibilidad	Evaluar el uso por personas mayores, la claridad de los flujos y los mensajes	NFR-USAB-1 a 4	CP-06, CP-20

Tipo	Propósito en Cuidarte+	Requisitos	Casos
Compatibilidad	Verificar navegadores y comportamiento responsivo	NFR-COMPAT-1, 2	CP-06, CP-22
Humo y regresión	Confirmar la estabilidad mínima antes de cada ciclo y que una corrección no rompe lo ya aprobado	RF críticos	Ciclo 1 y etapa 5

Priorizamos seguridad, auditoría y usabilidad porque Cuidarte+ maneja datos sensibles de salud y está orientado a personas mayores. El rendimiento se incluye porque el ERS fija umbrales medibles y porque el acceso oportuno a un examen tiene relevancia clínica, por ejemplo durante una urgencia. La combinación de análisis estático y dinámico se justifica porque cada uno detecta cosas distintas: SonarQube encuentra un secreto escrito en el código aunque nadie lo use, y ZAP encuentra una cabecera de seguridad faltante que no se ve en el código.

3.3 Criterios de aceptación

Estos criterios se aplican a todos los casos. Un caso puede tener un criterio propio en su ficha, pero nunca uno más débil que el general.

Criterio general. Un caso se marca como Aprobado solo si el resultado observado coincide con el esperado, se respeta la regla de negocio que corresponde (RB-1, RB-2 o RB-3), ningún dato clínico queda visible para un rol no autorizado y existe evidencia legible. Si aparece un problema de seguridad o de cumplimiento, el caso se marca como Falla aunque la pantalla muestre un comportamiento aparentemente correcto.

Tabla 6. Estados de resultado

Estado	Cuándo se usa
Aprobado	Se cumplen el criterio general y el criterio propio del caso
Falla	El resultado difiere del esperado o se detecta un problema de seguridad o cumplimiento. Requiere incidente con severidad
Bloqueado	El caso no se puede ejecutar por una causa externa (ambiente caído o dependencia de un caso fallido). Se anota la causa
No ejecutado	El caso no alcanzó a ejecutarse en el ciclo. No cuenta como cobertura de ejecución

Funcionales. Las operaciones CRUD deben funcionar y validar los datos en el servidor (ERS §3.1.2). El login correcto entrega un JWT y el cierre de sesión debe invalidarlo (RF-1). Las eliminaciones de exámenes y documentos deben pedir confirmación y ser lógicas (RF-3). La subida y la descarga de documentos no deben superar 10 segundos (RF-4), y cada acción crítica, incluida la descarga, debe generar un registro de auditoría (RF-5).

No funcionales. En seguridad, la auditoría con lista de verificación y las pruebas de penetración no deben mostrar hallazgos críticos (ERS §3.3.1). En rendimiento, el CRUD simple debe responder bajo 300 ms en el percentil 95 con carga normal, la página principal

debe cargar en menos de 2 segundos y el sistema debe sostener 200 usuarios concurrentes; estas mediciones valen solo con el retraso artificial de 5 segundos desactivado, y la medición con el retraso se informa aparte. En usabilidad, la prueba con cinco usuarios representativos, incluidos adultos mayores, no debe mostrar bloqueos mayores (ERS §3.1.1). En compatibilidad, los flujos principales deben funcionar en las dos últimas versiones de los cuatro navegadores y en vistas de móvil y tablet.

Reglas de negocio. Con token de paciente, toda operación de escritura debe responder 403 y el paciente solo puede ver sus propios exámenes (RB-1). La administración de usuarios y roles debe estar disponible para el administrador y rechazada para cualquier otro rol (RB-2). RB-3 se acepta si el médico accede a la información clínica tal como lo indica el ERS, y se registra al mismo tiempo la observación de cumplimiento OC-01 (sección 6.3).

Normativos. El acceso a la información clínica debe limitarse a quien participa en la atención y quedar registrado con fecha y persona (Ley 20.584 art. 13 y DS 41 art. 9), por lo que una descarga sin registro de auditoría se considera falla. Los datos clínicos no se eliminan físicamente antes de 15 años (Ley 20.584 art. 13 y DS 41 art. 11). Las contraseñas y los secretos no pueden quedar en texto plano ni en el repositorio (Ley 19.628 art. 11).

Certificación. El sistema puede recibir el dictamen Certificado solo si no hay incidentes críticos abiertos, todos los casos P0 están aprobados y los 40 códigos tienen un resultado de ejecución. Con incidentes graves abiertos que tengan plan de corrección, el máximo es Certificado con reservas. Con un incidente crítico abierto, el dictamen es No certificado.

3.4 Herramientas utilizadas

Tabla 7. Herramientas de prueba

Herramienta	Fundamento de uso en Cuidarte+	Casos
Selenium	Automatiza los flujos por rol en el frontend y permite repetirlos en varios navegadores	CP-01, 02, 08 a 12, 22
Postman / Swagger	Prueba la API directamente: códigos HTTP, reutilización de tokens y respuestas por rol	CP-01, 03, 07, 08, 11 a 13
OWASP ZAP	Análisis dinámico autenticado con token de médico y de paciente; en la EV1 solo se hizo el escaneo sin sesión	CP-04
Burp Suite	Manipulación manual de peticiones (rol, identificadores y cabeceras) para probar control de acceso	CP-04, CP-17
Nikto	Revisión de configuración del servidor web y de cabeceras	CP-04, CP-14
SQLMap	Búsqueda de inyección SQL en el login y en los parámetros de las rutas	CP-04
John the Ripper	Mide la resistencia de las contraseñas almacenadas en la base de prueba	CP-15
JMeter	Tiempo de respuesta CRUD, descarga de documentos y 200 usuarios concurrentes; reutiliza el plan CuidartePlus_CP05.jmx de la EV1	CP-05, CP-13, CP-19
SonarQube	Análisis estático de BACKEND y FRONTEND; sus hallazgos se leen frente a OWASP y a la normativa	CP-16, CP-17

Herramienta	Fundamento de uso en Cuidarte+	Casos
Lighthouse	Tiempo de carga de la página principal y accesibilidad básica	CP-06, CP-19

Respecto de la EV1 se retiraron Jest y k6. El repositorio no tiene pruebas unitarias ni script de test, y las pruebas de carga se hicieron con JMeter, así que mantenerlos en el plan no era coherente con lo que realmente usamos.

Recursos humanos

Tabla 8. Roles del equipo

Integrante	Rol en la EP3	Responsabilidades
Giannina Guerrero	Coordinación de QA e integración	Plan de pruebas, matriz de trazabilidad, análisis ético y normativo, dictamen e integración del informe
Nicolás Barra	QA funcional y de API	Casos funcionales y de reglas de negocio, ejecución con Selenium, Postman y SQLMap, registro de la ejecución
Skarlett Tropan	QA de calidad y normativa técnica	Criterios y tipos de prueba, SonarQube, verificaciones de TLS, cifrado y respaldo, usabilidad, formato del informe
Ari Araya	QA de seguridad y rendimiento	Ambiente Docker, OWASP ZAP, Burp Suite, Nikto, John the Ripper, JMeter y clasificación de la criticidad

Cada parte tiene a otro integrante como revisor, y como la defensa es individual, todos deben poder explicar el trabajo completo y no solo su parte.

Recursos técnicos

Tabla 9. Recursos técnicos

Recurso	Detalle
Stack del producto	Backend Node.js 18 (imagen node:18-alpine) con Express 4.19, jsonwebtoken 9 y multer; frontend React 19 con Vite 7, construido con Node 20 y servido por nginx; PostgreSQL 15 (postgres:15-alpine)
Orquestación	Docker Compose con tres servicios: frontend :3333, API :4444 (Swagger en /docs) y base de datos :15442
Navegadores	Chrome, Firefox y Edge en sus dos últimas versiones; Safari si hay un equipo disponible; vistas móvil (375 px) y tablet
Datos de prueba	Cuentas sintéticas admin.qa, medico.qa y paciente.qa; pacientes y exámenes ficticios, sin RUT ni datos reales
Código fuente	Repositorio Barrolas/cuidarte-mas, rama main (commit 7503d1b al iniciar la EP3)

Entorno de prueba

Todas las pruebas se ejecutan en el ambiente local Docker de cada integrante. No existe un ambiente de QA o staging separado, por lo que las verificaciones que dependen de producción, como TLS con certificado válido o la disponibilidad mensual, se hacen sobre la configuración del despliegue (nginx.conf y docker-compose.yml) y se informan con esa limitación. Las herramientas de seguridad se usan solo contra esta instalación local.

4. Diseño de casos de prueba

4.1 Matriz de trazabilidad

En la EV1 la matriz relacionaba 11 filas con seis casos y dejaba 21 de los 40 códigos del ERS B sin caso. Para la EP3 la reconstruimos completa: cada requisito funcional, no funcional y regla de negocio tiene un caso asignado con un identificador que no cambia durante la ejecución. CP-01 a CP-06 conservan su número de la EV1 para no romper la relación con las evidencias ya entregadas, y CP-07 a CP-23 son nuevos. La columna Riesgo usa la priorización de la sección 3.1.

Tabla 10. Matriz de trazabilidad ERS B, 40 de 40 códigos

Código	Requisito (ERS B)	Caso	Tipo de prueba	Riesgo	Ejecuta
REQUISITOS FUNCIONALES (17)					
RF-1.1	Autenticarse con nombre_usuario y contraseña	CP-01	Funcional y seguridad	P0	Nicolás
RF-1.2	Cierre de sesión y revocación de tokens	CP-07	Seguridad de sesión	P0	Nicolás
RF-2.1	Registro rápido con usuario, contraseña y correo; rol paciente por defecto	CP-09	Funcional; valores límite	P2	Nicolás
RF-2.2	Médico o administrador registra a un paciente	CP-10	Funcional	P2	Nicolás
RF-2.3	Médico o administrador edita el registro de un paciente	CP-10	Funcional	P2	Nicolás
RF-2.4	Médico o administrador visualiza el registro de un paciente	CP-10	Funcional; control de acceso	P0	Nicolás
RF-2.5	Administrador visualiza los usuarios registrados	CP-08	Funcional; RBAC	P0	Nicolás
RF-2.6	Administrador edita un usuario y le asigna roles	CP-08	Funcional; RBAC	P0	Nicolás
RF-2.7	Administrador elimina un usuario	CP-08	Funcional; auditoría	P0	Nicolás
RF-3.1	Médico registra un examen a un paciente	CP-02	Funcional	P2	Nicolás
RF-3.2	Médico edita el examen y sus documentos	CP-11	Funcional	P2	Nicolás
RF-3.3	Médico elimina el examen o sus documentos (baja lógica con confirmación)	CP-11	Funcional; cumplimiento	P1	Nicolás
RF-4.1	Paciente visualiza sus exámenes	CP-12	Funcional; control de acceso	P0	Nicolás
RF-4.2	Paciente descarga los documentos de sus exámenes (máximo 10 s)	CP-13	Funcional; rendimiento	P0	Nicolás
RF-4.3	Médico adjunta un documento por examen en PDF, DOC, PPT, JPG o PNG	CP-13	Funcional; partición de equivalencia	P2	Nicolás
RF-4.4	Documentos en storage interno y referenciados en la BD	CP-13	Integración	P1	Nicolás
RF-5.1	Auditar creación, edición, eliminación y subida o descarga de documentos	CP-03	Funcional; cumplimiento	P1	Nicolás
REQUISITOS NO FUNCIONALES (20)					
NFR-SEG-1	TLS obligatorio en todas las comunicaciones	CP-14	Seguridad; verificación de configuración	P0	Skarlett

Código	Requisito (ERS B)	Caso	Tipo de prueba	Riesgo	Ejecuta
NFR-SEG-2	Contraseñas con hashing seguro (bcrypt)	CP-15 y CP-01	Seguridad	P0	Ari
NFR-SEG-3	Cifrado de datos sensibles en reposo	CP-16	Seguridad; verificación de configuración	P0	Skarlett
NFR-SEG-4	Control de acceso por rol en el backend	CP-04 y CP-08	Seguridad	P0	Ari
NFR-SEG-5	Protección contra CSRF, XSS e inyección SQL; validación y saneamiento	CP-04	Seguridad	P0	Ari
NFR-SEG-6	Gestión de log segura	CP-17	Seguridad; cumplimiento	P1	Skarlett
NFR-SEG-7	Políticas de respaldo y recuperación definidas	CP-18	Operación; verificación de configuración	P1	Skarlett
NFR-SEG-8	Cumplimiento de la normativa de protección de datos personales	CP-23 (con CP-03 y CP-04)	Cumplimiento normativo	P0	Giannina
NFR-SEG-9	Manejo de sesión con token de acceso (JWT)	CP-01 y CP-07	Seguridad de sesión	P0	Nicolás y Ari
NFR-PERF-1	CRUD simple bajo 300 ms con carga normal	CP-05	Rendimiento	P3	Ari
NFR-PERF-2	Página principal bajo 2 s en conexión móvil promedio	CP-19	Rendimiento	P3	Ari
NFR-PERF-3	200 usuarios concurrentes por defecto	CP-19	Carga	P3	Ari
NFR-USAB-1	Tipografía legible, contraste y controles grandes para personas mayores	CP-06	Usabilidad; accesibilidad	P4	Skarlett
NFR-USAB-2	Flujos claros de registro y de visualización de exámenes o documentos	CP-06	Usabilidad	P4	Skarlett
NFR-USAB-3	Ayuda contextual y mensajes de error amigables	CP-20	Usabilidad	P4	Skarlett
NFR-USAB-4	Primero se accede al paciente y luego a sus exámenes	CP-06	Usabilidad; flujo	P4	Skarlett
NFR-DIS-1	Disponibilidad objetivo de 99,5 % mensual	CP-21	Disponibilidad; verificación documental	P3	Ari
NFR-DIS-2	Mantenimiento con ventana y migración segura de datos	CP-21	Mantenibilidad; verificación documental	P3	Ari
NFR-COMPAT-1	Últimas dos versiones de Chrome, Firefox, Safari y Edge	CP-22	Compatibilidad	P4	Skarlett
NFR-COMPAT-2	Responsivo en móviles y tablets	CP-06	Compatibilidad	P4	Skarlett
REGLAS DE NEGOCIO (3)					
RB-1	Un paciente solo tiene permisos de lectura	CP-04	Seguridad; RBAC	P0	Ari
RB-2	El administrador tiene acceso completo de escritura, lectura, actualización y eliminación	CP-08	Funcional; RBAC	P0	Nicolás
RB-3	Un médico puede ver la información clínica de cualquier paciente registrado	CP-10 y CP-02	Funcional; cumplimiento	P0	Nicolás

Tabla 11. Cobertura de diseño, EV1 frente a EP3

Bloque	Códigos en el ERS	Con caso en la EV1	Con caso en la EP3
Requisitos funcionales	17	4	17
Requisitos no funcionales	20	8	20
Reglas de negocio	3	2	3
Total	**40**	**14**	**40 (100 %)**

La cobertura de diseño queda en 40 de 40. Esto significa que ningún código del ERS queda sin un caso que lo verifique, pero todavía no dice si el sistema cumple. En la EV1 la columna Cobertura marcaba como cubierto todo requisito con un caso diseñado; ahora separamos las dos cosas, y la cobertura de ejecución se mide con los resultados de la sección 5.

Dos situaciones del ERS se dejan explícitas. RF-4.3 acepta PDF, DOC, PPT, JPG y PNG, pero el filtro de carga del backend (BACKEND/src/routes/documentos.js, líneas 15 a 27) solo admite PDF, JPG y PNG. Además, RF-4.4 pide guardar los documentos en storage interno con referencia en la base de datos, mientras que el backend guarda el archivo completo en una columna bytea. CP-13 revisa ambos puntos (INC-15 e INC-16).

4.2 Catálogo de casos

Tabla 12. Casos de prueba de la EP3

Caso	Nombre	Códigos ERS	Herramienta	Ejecuta
CP-01	Autenticación válida y rechazo de credenciales inválidas	RF-1.1, NFR-SEG-2, NFR-SEG-9	Postman/Swagger, Selenium	Nicolás
CP-02	Registro de examen médico por un profesional autorizado	RF-3.1, RB-3	Selenium, Postman	Nicolás
CP-03	Registro de auditoría ante acciones críticas, incluida la subida y la descarga	RF-5.1, NFR-SEG-8	Postman, consulta a la tabla auditoria	Nicolás
CP-04	Control de acceso por rol y resistencia a inyección	NFR-SEG-4, NFR-SEG-5, NFR-SEG-8, RB-1	OWASP ZAP autenticado, Burp Suite, Nikto, SQLMap	Ari y Nicolás
CP-05	Tiempo de respuesta de operaciones CRUD con y sin el retraso de 5 s	NFR-PERF-1	JMeter	Ari
CP-06	Usabilidad para adulto mayor y compatibilidad responsive	NFR-USAB-1, 2 y 4, NFR-COMPAT-2	Lista de verificación manual, Lighthouse	Skarlett
CP-07	Cierre de sesión y revocación del token	RF-1.2, NFR-SEG-9	Postman/Swagger	Nicolás
CP-08	Administración de usuarios por el administrador: listar, editar rol y eliminar	RF-2.5, 2.6, 2.7, NFR-SEG-4, RB-2	Selenium, Postman	Nicolás
CP-09	Registro rápido con rol paciente y política de contraseña	RF-2.1	Selenium, Postman	Nicolás
CP-10	Gestión de pacientes por médico y administrador	RF-2.2, 2.3, 2.4, RB-3	Selenium	Nicolás
CP-11	Edición y baja lógica de exámenes y documentos con confirmación	RF-3.2, RF-3.3	Selenium, Postman	Nicolás
CP-12	El paciente ve solo sus propios exámenes	RF-4.1	Selenium, Postman	Nicolás

Caso	Nombre	Códigos ERS	Herramienta	Ejecuta
CP-13	Carga y descarga de documentos: formatos, almacenamiento y tiempo	RF-4.2, 4.3, 4.4	Postman, JMeter (tiempos)	Nicolás y Ari
CP-14	Verificación de TLS en frontend y API	NFR-SEG-1	Revisión de nginx.conf y docker-compose, navegador, Nikto	Skarlett
CP-15	Almacenamiento de contraseñas y resistencia a cracking	NFR-SEG-2	Consulta a la BD de prueba, John the Ripper	Ari
CP-16	Cifrado en reposo de datos clínicos y documentos	NFR-SEG-3	Revisión del esquema y de la carpeta uploads, SonarQube	Skarlett
CP-17	Gestión de log y manejo de errores sin fuga de información	NFR-SEG-6	SonarQube, Burp Suite, revisión manual	Skarlett y Ari
CP-18	Respaldo y restauración de la base de datos	NFR-SEG-7	pg_dump y restauración en Docker	Skarlett
CP-19	Carga de la página principal y 200 usuarios concurrentes	NFR-PERF-2, NFR-PERF-3	Lighthouse, JMeter	Ari
CP-20	Ayuda contextual y mensajes de error comprensibles	NFR-USAB-3	Lista de verificación manual	Skarlett
CP-21	Disponibilidad y procedimiento de mantenimiento	NFR-DIS-1, NFR-DIS-2	Revisión documental y de docker-compose	Ari
CP-22	Compatibilidad con navegadores	NFR-COMPAT-1	Selenium en Chrome, Firefox y Edge; Safari si hay equipo	Skarlett
CP-23	Verificación de cumplimiento normativo	NFR-SEG-8	Checklist de la Tabla 6.1 del análisis normativo	Giannina

4.3 Casos detallados

Se presentan ocho casos con ficha completa, que cubren los distintos tipos de requisito del ERS: funcionales (CP-02, CP-08), de seguridad (CP-01, CP-04, CP-07), de auditoría y cumplimiento (CP-03), de rendimiento (CP-05) y de usabilidad y compatibilidad (CP-06). Las fichas de CP-01 a CP-06 vienen de la EV1 con los ajustes indicados en el Anexo A.

Tabla 13. Ficha del caso CP-01

ID	NOMBRE	REQUERIMIENTO
CP-01	Autenticación válida y rechazo de credenciales inválidas	RF-1.1: autenticarse con nombre_usuario y contraseña. NFR-SEG-2: hash seguro de contraseñas. NFR-SEG-9: sesión con token JWT.
DESCRIPCIÓN		
Verificar que un usuario válido obtiene una sesión JWT, que las credenciales inválidas se rechazan sin revelar si la cuenta existe y que la contraseña no se guarda ni se compara en texto plano.		
PRECONDICIONES		
Ambiente Docker local arriba (API en http://localhost:4444). Usuario medico.qa creado con rol médico y contraseña conforme a la política del ERS.		
PASOS		
1. Enviar POST /autenticacion/login con credenciales válidas. 2. Verificar que la respuesta trae un token JWT y revisar su expiración. 3. Repetir con contraseña incorrecta y con un usuario inexistente. 4. Comparar código y mensaje de ambos rechazos. 5. Revisar en la tabla de usuarios cómo quedó guardada la contraseña.		
RESULTADO ESPERADO		
El login válido responde 200 con un JWT de vigencia acotada. Los dos rechazos responden 401 con el mismo mensaje genérico y sin token. La contraseña se guarda como hash bcrypt.		
CRITERIO DE ACEPTACIÓN		
Se genera el token solo con credenciales válidas, el rechazo no revela si el usuario existe y no hay contraseñas en texto plano en la base ni en los registros.		
DATOS DE PRUEBA		
Válido: medico.qa / PruebaSegura#2026. Inválido: medico.qa / ClaveIncorrecta#1. Inexistente: noexiste.qa / ClaveIncorrecta#1.		
TIPO DE PRUEBA		
Funcional y de seguridad		

Tabla 14. Ficha del caso CP-02

ID	NOMBRE	REQUERIMIENTO
CP-02	Registro de examen médico por un profesional autorizado	RF-3.1: el médico registra un examen a un paciente. RB-3: el médico puede ver la información clínica de los pacientes.
DESCRIPCIÓN		
Validar que un médico autenticado puede crear un examen asociado a un paciente existente y que el servidor valida los campos obligatorios.		
PRECONDICIONES		
Sesión activa de médico. Paciente de prueba registrado.		
PASOS		
1. Iniciar sesión como médico. 2. Seleccionar el paciente de prueba. 3. Registrar un examen con datos válidos y adjuntar un PDF dentro del límite. 4. Confirmar que aparece en el listado y en el detalle (GET /examenes/paciente/:paciente_id). 5. Intentar guardar un examen sin campos obligatorios, desde la interfaz y con POST /examenes.		
RESULTADO ESPERADO		
El examen se crea con respuesta 201 y queda asociado al paciente. El intento sin campos obligatorios se rechaza con un mensaje comprensible, también por API.		
CRITERIO DE ACEPTACIÓN		
El CRUD de exámenes opera según el ERS, la validación funciona en el servidor y el médico accede a la información clínica según RB-3.		
DATOS DE PRUEBA		
Paciente de prueba; tipo de examen hemograma completo; fecha de emisión del día; observación "control rutinario"; PDF de 200 KB.		
TIPO DE PRUEBA		
Funcional		

Tabla 15. Ficha del caso CP-03

ID	NOMBRE	REQUERIMIENTO
CP-03	Registro de auditoría ante acciones críticas	RF-5.1: auditar creación, edición y eliminación de registros y subida o descarga de documentos. NFR-SEG-6: gestión de log segura.
DESCRIPCIÓN		
Comprobar que cada acción crítica, incluidas la subida y la descarga de documentos, genera un registro de auditoría con actor, acción, fecha y recurso, y que nadie puede escribir registros falsos.		
PRECONDICIONES		
Examen con documento creado en CP-02. Usuarios médico y paciente disponibles.		
PASOS		
1. Como médico, editar y luego eliminar un examen de prueba. 2. Subir un documento a otro examen. 3. Como paciente, descargar ese documento (GET /documentos/:id). 4. Consultar GET /auditoria y verificar un registro por cada acción. 5. Con token de paciente, intentar POST /auditoria con un registro inventado.		
RESULTADO ESPERADO		
Existe un registro por cada acción, incluida la descarga, sin contraseñas ni tokens. POST /auditoria con token de paciente se rechaza.		
CRITERIO DE ACEPTACIÓN		
Se audita cada acción crítica del ERS. La falta de registro de la descarga o la posibilidad de escribir registros desde el cliente hacen fallar el caso.		
DATOS DE PRUEBA		
Examen y documento de CP-02; usuarios medico.qa y paciente.qa.		
TIPO DE PRUEBA		
Funcional y de cumplimiento (auditoría)		

Tabla 16. Ficha del caso CP-04

ID	NOMBRE	REQUERIMIENTO
CP-04	Control de acceso por rol y resistencia a inyección	NFR-SEG-4: control de acceso por rol en backend. NFR-SEG-5: protección contra CSRF, XSS e inyección SQL. RB-1: el paciente solo lee.
DESCRIPCIÓN		
Verificar que un paciente no puede ejecutar operaciones de administración ni ver datos ajenos, y que las entradas maliciosas se rechazan o se sanean.		
PRECONDICIONES		
Usuarios de los tres roles. OWASP ZAP configurado con token de paciente y de médico.		
PASOS		
1. Autenticarse como paciente y guardar el token. 2. Invocar GET /usuarios y DELETE /usuarios/:id. 3. Pedir el examen y el documento de otro paciente cambiando el identificador (Burp Suite). 4. Ejecutar SQLMap sobre el login y los parámetros de /examenes. 5. Enviar <script>alert(1)</script> en observaciones y revisar si se ejecuta. 6. Correr ZAP autenticado y Nikto sobre :3333 y :4444.		
RESULTADO ESPERADO		
Los accesos indebidos responden 401 o 403. La inyección SQL no autentica ni altera consultas. El script no se ejecuta. ZAP y Nikto no reportan hallazgos altos.		
CRITERIO DE ACEPTACIÓN		
El control de acceso es efectivo en el backend y no hay hallazgos críticos de inyección ni de acceso a datos de otro paciente.		
DATOS DE PRUEBA		
Token de paciente.qa. Login con ' OR 1=1 --. Campo observaciones con <script>alert(1)</script>. Identificador de un examen de otro paciente.		
TIPO DE PRUEBA		
No funcional: seguridad		

Tabla 17. Ficha del caso CP-05

ID	NOMBRE	REQUERIMIENTO
CP-05	Tiempo de respuesta de operaciones CRUD bajo carga normal	NFR-PERF-1: operaciones CRUD simples bajo 300 ms con carga normal.
DESCRIPCIÓN		
Medir el tiempo de respuesta del CRUD de pacientes y exámenes con carga normal y compararlo con el umbral del ERS, con y sin el retraso artificial de 5 s que tiene el backend.		
PRECONDICIONES		
Ambiente estable con datos sintéticos y sin otras pruebas en curso. Para la medición formal, delayMiddleware(5000) desactivado en examenes.js, pacientes.js y documentos.js.		
PASOS		
1. Abrir el plan CuidartePlus_CP05.jmx. 2. Ejecutar con el retraso activo (línea base de la EV1). 3. Desactivar el retraso y reiniciar el backend. 4. Ejecutar de nuevo durante cinco minutos. 5. Comparar el percentil 95 de cada petición con 300 ms.		
RESULTADO ESPERADO		
Sin el retraso, el p95 de las operaciones CRUD simples queda bajo 300 ms durante toda la ventana.		
CRITERIO DE ACEPTACIÓN		
Se cumple el umbral sin el retraso y se adjunta el reporte HTML de JMeter. La corrida con retraso se informa aparte.		
DATOS DE PRUEBA		
Grupo A: 20 usuarios virtuales con GET y POST sobre pacientes y exámenes. Grupo B: 50 usuarios virtuales como prueba de concurrencia.		
TIPO DE PRUEBA		
No funcional: rendimiento		

Tabla 18. Ficha del caso CP-06

ID	NOMBRE	REQUERIMIENTO
CP-06	Usabilidad para adulto mayor y compatibilidad responsiva	NFR-USAB-1, 2 y 4 (legibilidad, flujos claros, primero paciente y luego exámenes). NFR-COMPAT-2: responsivo en móvil y tablet.
DESCRIPCIÓN		
Evaluar que un paciente adulto mayor complete el acceso a sus exámenes en móvil y tablet con texto legible, buen contraste y controles fáciles de tocar.		
PRECONDICIONES		
Frontend en http://localhost:3333. Paciente con al menos un examen y un documento.		
PASOS		
1. Abrir la aplicación con viewport de 375 px. 2. Iniciar sesión como paciente. 3. Ir del perfil al listado de exámenes, al detalle y a la descarga. 4. Revisar contraste, tamaño de fuente y de controles con la lista de verificación y Lighthouse. 5. Repetir en tablet y en otro navegador.		
RESULTADO ESPERADO		
El flujo se completa sin bloqueos, la interfaz se adapta al tamaño de pantalla y el documento se abre o descarga correctamente.		
CRITERIO DE ACEPTACIÓN		
La sesión con usuarios representativos termina sin bloqueos mayores y se alcanza el puntaje mínimo de la lista de verificación.		
DATOS DE PRUEBA		
Viewport 375 px y tablet; usuario paciente.qa; lista de verificación de contraste y tamaño de controles.		
TIPO DE PRUEBA		
No funcional: usabilidad y compatibilidad		

Tabla 19. Ficha del caso CP-07

ID	NOMBRE	REQUERIMIENTO
CP-07	Cierre de sesión y revocación del token	RF-1.2: cierre de sesión y revocación de tokens. NFR-SEG-9: sesión con token JWT.
DESCRIPCIÓN		
Comprobar que, al cerrar sesión, el token emitido deja de ser aceptado por la API, para que una sesión olvidada en un equipo compartido no siga abierta.		
PRECONDICIONES		
Ambiente Docker arriba. Usuario médico con al menos un examen visible.		
PASOS		
1. Iniciar sesión con POST /autenticacion/login y guardar el token. 2. Consultar GET /examenes con ese token (200). 3. Cerrar sesión desde la interfaz y buscar en Swagger un endpoint de logout o revocación. 4. Repetir GET /examenes con el mismo token. 5. Registrar el código obtenido y cuánto tiempo sigue siendo aceptado el token.		
RESULTADO ESPERADO		
Después del cierre de sesión la API responde 401 al token anterior, porque existe un logout que lo invalida en el servidor.		
CRITERIO DE ACEPTACIÓN		
El logout invalida la sesión (criterio de RF-1). Si el token sigue funcionando, el caso falla aunque la interfaz vuelva a la pantalla de login.		
DATOS DE PRUEBA		
Usuario medico.qa; token JWT del paso 1.		
TIPO DE PRUEBA		
No funcional: seguridad de sesión, con verificación funcional del cierre		

Tabla 20. Ficha del caso CP-08

ID	NOMBRE	REQUERIMIENTO
CP-08	Administración de usuarios por el administrador	RF-2.5, RF-2.6 y RF-2.7 (listar, editar con roles y eliminar usuarios). NFR-SEG-4. RB-2.
DESCRIPCIÓN		
Verificar que el administrador puede gestionar usuarios de punta a punta y que ningún otro rol puede hacerlo, ni por /usuarios ni por /roles.		
PRECONDICIONES		
Cuentas de administrador y de médico. Un usuario sintético creado para editar y eliminar.		
PASOS		
1. Como administrador, listar con GET /usuarios. 2. Editar el usuario de prueba con PUT /usuarios/:id y asignarle rol médico. 3. Eliminarlo desde la interfaz y verificar que pide confirmación. 4. Revisar en la base y en la auditoría si la baja fue lógica o física. 5. Como médico, repetir PUT /usuarios/:id e intentar POST /roles y DELETE /roles/:id.		
RESULTADO ESPERADO		
El administrador lista, edita y elimina con respuesta 200; la eliminación pide confirmación, queda auditada y es lógica. Con token de médico, /usuarios y /roles responden 403.		
CRITERIO DE ACEPTACIÓN		
Las tres operaciones funcionan solo para el administrador y el control se aplica en el backend. Cualquier operación de administración aceptada con otro rol hace fallar el caso.		
DATOS DE PRUEBA		
Usuario sintético usuario.prueba08 con correo ficticio; tokens de admin.qa y medico.qa.		
TIPO DE PRUEBA		
Funcional y de seguridad (control de acceso)		

5. Ejecución de pruebas

5.1 Resumen de ejecución

El diseño de la EP3 contempla 23 casos que cubren los 40 códigos del ERS B. Las tablas siguientes se completan al cerrar el ciclo 2 con los números de la sección 5.2, y ambas cifras deben cuadrar.

Tabla 21. Resumen general de la ejecución

Indicador	Valor
Requisitos del ERS cubiertos por diseño	40 de 40 (100 %)
Casos de prueba diseñados	23 (CP-01 a CP-23)
Casos ejecutados	**«[Pendiente]»**
Aprobados	**«[Pendiente]»**
Fallidos	**«[Pendiente]»**
Bloqueados	**«[Pendiente]»**
No ejecutados	**«[Pendiente]»**
Incidentes registrados por severidad	**«[Pendiente]»** Propuesta inicial: 1 crítico, 7 graves, 7 moderados y 1 leve (ver 5.3)

Tabla 22. Resultados por tipo de prueba

Tipo de prueba	Diseñados	Ejecutados	Aprobados	Fallidos	Bloqueados
Funcionales	7				
Integración y auditoría	2				
Seguridad	4				
Configuración y cumplimiento	5				
Rendimiento	2				
Usabilidad y compatibilidad	3				
Total	**23**				

«[Pendiente: completar ambas tablas al cierre del ciclo 2. Responsable: Nicolás Barra, con datos de Ari Araya y Skarlett Tropan]»

Evidencia previa de la EV1

En la EV1 hicimos una ejecución exploratoria los días 7 y 8 de septiembre de 2026 en el mismo ambiente Docker. No reemplaza al ciclo 2 de la EP3, pero sirve como línea base y adelanta resultados que la ejecución debe confirmar.

Tabla 23. Resultados exploratorios de la EV1 (línea base)

Caso	Prueba realizada en la EV1	Resultado observado	Fuente
CP-01	Login con el usuario semilla medico/medico	200 con JWT; la contraseña se compara en texto plano (HALL-02)	Informe de hallazgos EV1

Caso	Prueba realizada en la EV1	Resultado observado	Fuente
CP-04	Paciente invoca GET /usuarios	403: el control de rol funciona en esa ruta	Informe de hallazgos EV1
CP-04	Login con ' OR 1=1 --	401 sin token (consulta parametrizada)	Informe de hallazgos EV1
CP-04	OWASP ZAP baseline sin sesión (frontend y API)	0 FAIL; advertencias por cabeceras faltantes (CSP, anti-clickjacking, X-Content-Type-Options), X-Powered-By y CORS amplio	Informe OWASP ZAP EV1 y anexos
CP-05	JMeter, 220 muestras, retraso activo	Login p95 ≈ 14 ms (cumple); GET /pacientes y /examenes p95 ≈ 5.008 a 5.011 ms (no cumple); 0 % de error	Informe JMeter CP-05
CP-02, CP-06	Botón Ver Documento en el formulario de examen	Abre el selector de archivos en lugar del documento (HALL-01); la API sí responde 200 con el PDF	Informe de hallazgos EV1

5.2 Detalle de ejecución de casos

Cada caso se registra con su resultado, la evidencia (captura o archivo de la herramienta), el incidente asociado cuando falla y la fecha y persona que lo ejecuta. La columna Incidente esperado indica lo que la revisión del código hace prever; si la ejecución no lo confirma, se deja constancia.

Tabla 24. Detalle de ejecución por caso

Caso	Descripción	Resultado	Evidencia	Incidente esperado	Fecha / ejecuta
PRUEBAS: FUNCIONALES					
CP-01	Autenticación válida y rechazo de credenciales inválidas	«[Pendiente]»	«[Captura]» Línea base EV1: login semilla 200	INC-01, INC-02	«[Fecha]» Nicolás
CP-02	Registro de examen médico por un profesional autorizado	«[Pendiente]»	«[Captura]»	INC-04	«[Fecha]» Nicolás
CP-08	Administración de usuarios por el administrador: listar, editar rol y eliminar	«[Pendiente]»	«[Captura]»	INC-07, INC-09	«[Fecha]» Nicolás
CP-09	Registro rápido con rol paciente y política de contraseña	«[Pendiente]»	«[Captura]»	INC-10	«[Fecha]» Nicolás
CP-10	Gestión de pacientes por médico y administrador	«[Pendiente]»	«[Captura]»	OC-01	«[Fecha]» Nicolás
CP-11	Edición y baja lógica de exámenes y documentos con confirmación	«[Pendiente]»	«[Captura]»	INC-09	«[Fecha]» Nicolás
CP-12	El paciente ve solo sus propios exámenes	«[Pendiente]»	«[Captura]»	Ninguno	«[Fecha]» Nicolás
PRUEBAS: INTEGRACIÓN Y AUDITORÍA					
CP-03	Registro de auditoría ante acciones críticas, incluida la subida y la descarga	«[Pendiente]»	«[Captura]»	INC-13, INC-14	«[Fecha]» Nicolás
CP-13	Carga y descarga de documentos: formatos, almacenamiento y tiempo	«[Pendiente]»	«[Captura]»	INC-12, 15, 16	«[Fecha]» Nicolás y Ari
PRUEBAS: SEGURIDAD					

Caso	Descripción	Resultado	Evidencia	Incidente esperado	Fecha / ejecuta
CP-04	Control de acceso por rol y resistencia a inyección	«[Pendiente]»	«[Captura]» Línea base EV1: 403, 401 y ZAP sin sesión	INC-05, INC-08	«[Fecha]» Ari y Nicolás
CP-07	Cierre de sesión y revocación del token	«[Pendiente]»	«[Captura]»	INC-03	«[Fecha]» Nicolás
CP-15	Almacenamiento de contraseñas y resistencia a cracking	«[Pendiente]»	«[Captura]»	INC-01	«[Fecha]» Ari
CP-17	Gestión de log y manejo de errores sin fuga de información	«[Pendiente]»	«[Captura]»	INC-06, 11, 14	«[Fecha]» Skarlett y Ari
PRUEBAS: CONFIGURACIÓN Y CUMPLIMIENTO					
CP-14	Verificación de TLS en frontend y API	«[Pendiente]»	«[Captura]»	Por verificar	«[Fecha]» Skarlett
CP-16	Cifrado en reposo de datos clínicos y documentos	«[Pendiente]»	«[Captura]»	INC-16	«[Fecha]» Skarlett
CP-18	Respaldo y restauración de la base de datos	«[Pendiente]»	«[Captura]»	Por verificar	«[Fecha]» Skarlett
CP-21	Disponibilidad y procedimiento de mantenimiento	«[Pendiente]»	«[Captura]»	Por verificar	«[Fecha]» Ari
CP-23	Verificación de cumplimiento normativo	«[Pendiente]»	«[Captura]»	Según resultados	«[Fecha]» Giannina
PRUEBAS: RENDIMIENTO					
CP-05	Tiempo de respuesta de operaciones CRUD con y sin el retraso de 5 s	«[Pendiente]»	«[Captura]» Línea base EV1: p95 ≈ 5 s con retraso	INC-04	«[Fecha]» Ari
CP-19	Carga de la página principal y 200 usuarios concurrentes	«[Pendiente]»	«[Captura]»	INC-04	«[Fecha]» Ari
PRUEBAS: USABILIDAD Y COMPATIBILIDAD					
CP-06	Usabilidad para adulto mayor y compatibilidad responsive	«[Pendiente]»	«[Captura]» Línea base EV1: HALL-01	INC-12	«[Fecha]» Skarlett
CP-20	Ayuda contextual y mensajes de error comprensibles	«[Pendiente]»	«[Captura]»	INC-06	«[Fecha]» Skarlett
CP-22	Compatibilidad con navegadores	«[Pendiente]»	«[Captura]»	Ninguno	«[Fecha]» Skarlett

«[Pendiente: resultados del ciclo 2 con capturas legibles. Funcionales e integración: Nicolás Barra. Seguridad y rendimiento: Ari Araya. Configuración, usabilidad y compatibilidad: Skarlett Tropan. CP-23: Giannina Guerrero]»

5.3 Criticidad de incidentes

Adaptamos la escala del formato al contexto de Cuidarte+. Como el sistema guarda datos de salud, la exposición de información clínica o de credenciales se considera crítica aunque el sistema siga funcionando.

Tabla 25. Escala de criticidad

Nivel	Descripción en Cuidarte+	Impacto	Acción requerida
CRÍTICO	Expone datos clínicos o credenciales, permite suplantar usuarios o impide usar una función esencial (login, consulta de exámenes)	Muy alto: compromete la confidencialidad o la continuidad de la atención y el cumplimiento legal	Remediación inmediata; bloquea la certificación
GRAVE	Afecta un control de seguridad o una función importante, pero existe una forma de seguir operando	Alto: debilita el acceso, la sesión, la trazabilidad o la conservación de la ficha	Corrección urgente con plan y fecha
MODERADO	Afecta funciones secundarias o el endurecimiento del sistema sin detener el flujo principal	Medio: el usuario trabaja con molestias o el riesgo depende de otra falla	Se corrige en la próxima iteración
LEVE	Defecto de apariencia, texto o desviación menor del ERS sin efecto en la operación ni en los datos	Bajo: no impacta la operación	Se corrige según disponibilidad

La tabla siguiente lista los incidentes que la revisión del código del repositorio (commit 7503d1b) hace esperar, con la severidad que proponemos. La columna Resultado se completa con la ejecución; si un incidente no se confirma, se retira y se informa.

Tabla 26. Incidentes y criticidad propuesta

Incidente	Caso	Descripción	Resultado	Impacto propuesto
PRUEBAS FUNCIONALES Y DE INTEGRACIÓN				
INC-09	CP-08, CP-11	Borrado físico (DELETE FROM) de exámenes, documentos, pacientes y usuarios; el ERS pide baja lógica	«[Pendiente]»	**GRAVE**
INC-12	CP-06, CP-13	El botón Ver Documento no muestra el adjunto (HALL-01 de la EV1)	«[Pendiente]»	**MODERADO**
INC-13	CP-03	La descarga de documentos no deja registro en la auditoría	«[Pendiente]»	**GRAVE**
INC-15	CP-13	El filtro de carga acepta solo PDF, JPG y PNG; el ERS pide además DOC y PPT	«[Pendiente]»	**LEVE**
INC-16	CP-13, CP-16	Archivo guardado en una columna bytea y carpeta uploads/documentos publicada sin autenticación	«[Pendiente]»	**MODERADO**
PRUEBAS DE SEGURIDAD				
INC-01	CP-01, CP-15	Contraseñas guardadas y comparadas en texto plano; usuarios semilla con contraseña igual al nombre	«[Pendiente]»	**CRÍTICO**
INC-02	CP-01	Secreto JWT por defecto "inseguro" y secreto real publicado en el README y en el .env versionado	«[Pendiente]»	**GRAVE**
INC-03	CP-07	No existe logout ni revocación; el token dura 2 horas	«[Pendiente]»	**GRAVE**
INC-05	CP-04	CORS abierto, sin cabeceras de seguridad ni límite de intentos de login	«[Pendiente]»	**MODERADO**
INC-06	CP-17, CP-20	Los errores 500 devuelven el mensaje interno al cliente	«[Pendiente]»	**MODERADO**
INC-07	CP-08	/roles permite crear, editar y borrar roles con cualquier token válido	«[Pendiente]»	**GRAVE**
INC-08	CP-04	Token guardado en localStorage, expuesto ante un XSS	«[Pendiente]»	**MODERADO**

Incidente	Caso	Descripción	Resultado	Impacto propuesto
INC-10	CP-09	Contraseña mínima de 6 caracteres; el ERS exige 12 con complejidad	«[Pendiente]»	**MODERADO**
INC-11	CP-17	Dependencias con vulnerabilidades conocidas (npm audit en backend y frontend)	«[Pendiente]»	**GRAVE**
INC-14	CP-03, CP-17	POST /auditoria permite a cualquier usuario con token escribir registros	«[Pendiente]»	**MODERADO**
PRUEBAS NO FUNCIONALES DE RENDIMIENTO				
INC-04	CP-05, CP-19	delayMiddleware(5000) agrega 5 s a exámenes, pacientes y documentos	EV1: confirmado con JMeter «[EP3: Pendiente]»	**GRAVE**

Además se registra la observación de cumplimiento OC-01, que no es un defecto del software sino de la regla RB-3 del ERS (sección 6.3). Mientras INC-01 siga abierto, el dictamen no puede ser Certificado.

«[Pendiente: confirmar cada severidad con la evidencia de ejecución y asignar el identificador BUG correspondiente. Responsable: Ari Araya]»

5.4 Análisis estático con SonarQube

El análisis estático revisa el código fuente sin ejecutarlo. Se aplica por separado a BACKEND y FRONTEND con SonarQube, y sus hallazgos se leen frente a OWASP Top 10 y a la normativa de la sección 6. La revisión manual del código que hicimos al preparar la matriz permite anticipar qué debería aparecer.

Tabla 27. Resultados de SonarQube

Métrica	BACKEND	FRONTEND
Quality Gate	«[Pendiente]»	«[Pendiente]»
Bugs	«[Pendiente]»	«[Pendiente]»
Vulnerabilidades	«[Pendiente]»	«[Pendiente]»
Security Hotspots	«[Pendiente]»	«[Pendiente]»
Code Smells	«[Pendiente]»	«[Pendiente]»
Duplicación (%)	«[Pendiente]»	«[Pendiente]»
Cobertura de pruebas	Sin pruebas unitarias en el repositorio	Sin pruebas unitarias en el repositorio

Tabla 28. Hallazgos estáticos esperados y su lectura legal

Hallazgo esperado	Ubicación	Categoría OWASP	Norma relacionada
Secreto escrito en el código ("inseguro")	routes/*.js (7 archivos)	Fallas criptográficas y de autenticación	Ley 19.628 art. 11; DS 41 art. 9
Comparación de contraseña en texto plano	routes/auth.js, líneas 21 y 110	Fallas criptográficas y de autenticación	Ley 19.628 art. 11; Ley 20.584 art. 12
Mensajes de error internos enviados al cliente	routes/*.js (bloques catch)	Configuración de seguridad incorrecta	NFR-SEG-6; Ley 19.628 art. 11
CORS permisivo	app.js, línea 21	Configuración de seguridad incorrecta	DS 41 art. 8
Token en localStorage	context/ AuthContext.jsx	Fallas de autenticación	DS 41 art. 8

Hallazgo esperado	Ubicación	Categoría OWASP	Norma relacionada
Dependencias vulnerables	package.json de ambos módulos	Componentes vulnerables y desactualizados	Ley 19.628 art. 11; Ley 17.336 arts. 78 y 79

«[Pendiente: ejecutar SonarQube en BACKEND y FRONTEND, completar las métricas, adjuntar capturas y confirmar o descartar los hallazgos esperados. Responsable: Skarlett Tropan]»

6. Análisis ético y normativo de los resultados

6.1 Enfoque

En la EV1 construimos el marco legal casi por completo desde la protección de datos y la ciberseguridad. En la revisión de la EV1 el docente nos indicó que faltaba la normativa propia del caso, en particular la ley de derechos de los pacientes y lo relativo a la atención de urgencia, y que había información con discordancias. Cuidarte+ guarda exámenes y documentos clínicos, así que la primera norma que lo regula es la que establece los derechos de los pacientes y las reglas de la ficha clínica.

Esta versión pone la normativa sanitaria en el centro (Ley 20.584, su modificación por la Ley 21.668 y el reglamento de fichas clínicas, Decreto 41 de 2012 del MINSAL), separa lo vigente de lo que entra en vigencia en diciembre de 2026 y corrige las citas de la EV1 que no correspondían (Anexo A).

La mayoría de estas leyes no obligan al software, sino a quien lo usa para tratar datos o atender pacientes, que en este caso es el centro de salud que opere Cuidarte+. CreaLab, como desarrollador, queda obligado de forma indirecta: si entrega un sistema que no permite cumplir la ley, el prestador tampoco podrá cumplirla. Por eso cada norma termina en una exigencia que se puede verificar con un caso de la matriz.

6.2 Marco normativo aplicable

La vigencia de cada norma se revisó al 19 de octubre de 2026 en los textos publicados en LeyChile y en las copias entregadas en el curso.

Tabla 29. Marco normativo aplicado a Cuidarte+

Norma	Estado	Artículos considerados	Exigencia y caso que la verifica
Ley 20.584, derechos y deberes de las personas en su atención de salud	Vigente	Art. 5 a) y 5° bis (información comprensible y atención preferente a mayores de 60 años); art. 10 (información al paciente, con regla para urgencias); art. 12 (ficha clínica en soporte electrónico, autenticidad de los cambios; datos de exámenes como sensibles); art. 13 (conservación de al menos 15 años, acceso solo de quienes participan en la atención, copia al titular); art. 15 b) (urgencia sin consentimiento)	Acceso restringido: CP-04, CP-10 y OC-01. Autenticidad de los cambios: CP-03 y CP-11. Copia al titular: CP-12 y CP-13. Conservación: CP-11
Ley 21.668, interoperabilidad de fichas clínicas (modifica los arts. 12 y 13 de la Ley 20.584)	Vigente desde el 28-05-2024	Nuevo texto de los arts. 12 y 13; art. tercero transitorio (actualización del reglamento)	Sin estándar técnico publicado que probar; queda como recomendación de diseño
Decreto 41 de 2012, MINSAL, reglamento sobre fichas clínicas	Vigente	Art. 8 (respaldo, barreras ante accesos no autorizados, restauración); art. 9 (acceso controlado y registro de quién accedió y cuándo); art. 11 (conservación de 15 años); art. 12 (eliminación con acta)	Registro de lecturas y descargas: CP-03. Respaldo: CP-18. Barreras de acceso: CP-04 y CP-14. Eliminación controlada: CP-11
Ley 19.628, protección de la vida privada	Vigente (texto actual hasta el 30-11-2026)	Art. 2 g) (datos sensibles, incluye estados de salud); art. 7 (secreto); art. 10 (tratamiento de datos sensibles); art. 11 (cuidado con la debida diligencia); art. 23 (indemnización)	Base actual de la responsabilidad por INC-01 e INC-02: CP-01 y CP-15
Ley 21.719, protección y tratamiento de datos personales	Publicada el 13-12-2024; vigente desde el 01-12-2026	Nuevo texto de la Ley 19.628: art. 3 (principios); art. 14 quinquies (medidas de seguridad); art. 14 sexies (reporte de vulneraciones); art. 16 bis (datos de salud); arts. 34 ter, 34 quáter y 35 (infracciones y multas)	Se cita como norma de vigencia próxima. Cifrado en reposo: CP-16. Restauración: CP-18
Ley 21.663, Ley Marco de Ciberseguridad	Vigente	Art. 4 (la prestación institucional de salud es servicio esencial); art. 9 (alerta temprana al CSIRT en tres horas); art. 27 (incidente de efecto significativo)	La obligada es la institución. El sistema debe dejar registros útiles para reportar a tiempo: CP-03 y CP-17
DFL 1 de 2005, MINSAL, arts. 141 y 173 (atención de urgencia, origen en la Ley 19.650)	Vigente	Prohíbe exigir garantías de pago o condicionar la atención de urgencia	Cuidarte+ no gestiona pagos ni admisión, por lo que no aplica en forma directa. Sí importa el acceso oportuno a exámenes en una urgencia: CP-05, CP-19 y CP-21
Ley 21.459, delitos informáticos	Vigente	Arts. 1 a 4 (ataque a la integridad, acceso ilícito, interceptación, ataque a los datos)	Explica el impacto de cada falla de acceso y limita nuestras pruebas al ambiente local
Ley 17.336, propiedad intelectual	Vigente	Arts. 78 y 79	Revisión de licencias de dependencias junto con npm audit (INC-11)
Manual de Accesibilidad Web del Gobierno de Chile	Guía técnica	Criterios alineados con WCAG; se complementa con la Ley 20.584 arts. 5 a) y 5° bis	CP-06 y CP-20

El Código Sanitario figuraba en la EV1 como texto suelto, sin artículos y con referencias a farmacias y sustancias que no corresponden al caso, por lo que se retiró. La Ley 19.799 y el

Decreto 181 solo aplican si los informes se firman electrónicamente, lo que el ERS no pide, y la Ley 21.180 solo si el sistema interopera con organismos públicos.

6.3 Tensión entre el ERS y la ley

Al cruzar el ERS con la Ley 20.584 encontramos un punto que no vimos en la EV1. La regla RB-3 dice que un médico puede ver la información clínica de cualquier paciente registrado. El artículo 13 de la Ley 20.584 dispone que quienes no estén directamente relacionados con la atención no tendrán acceso a la ficha, incluido el personal de salud del mismo prestador que no participa en esa atención, y el artículo 9 del DS 41 agrega que el acceso debe ser controlado y registrado. RB-2 tiene un problema parecido, porque entrega acceso completo a un administrador que no participa en la atención.

Como equipo de QA no podemos cambiar el ERS, pero sí informarlo. RB-3 se prueba tal como está escrita y, en paralelo, se registra como observación de cumplimiento OC-01. Una alternativa sería limitar el acceso del médico a los pacientes que atiende y habilitar un acceso de emergencia justificado y registrado para las urgencias, en línea con el artículo 15 b) de la misma ley. Es una propuesta para conversar con el cliente, no una exigencia del ERS actual.

6.4 Hallazgos y deber legal afectado

Tabla 30. Incidentes y deber legal afectado

Incidente	Hallazgo	Norma afectada
INC-01	Contraseñas en texto plano	Ley 19.628 art. 11; Ley 20.584 art. 12; DS 41 art. 8. Desde el 01-12-2026, art. 14 quinquies
INC-02	Secreto JWT por defecto y publicado	Ley 20.584 art. 13; DS 41 art. 9; facilita la conducta del art. 2 de la Ley 21.459
INC-03	Sin logout ni revocación	Ley 20.584 art. 13; DS 41 art. 9
INC-04	Retraso artificial de 5 s	Ley 20.584 arts. 12 y 13 (acceso oportuno); DS 41 art. 8
INC-07	/roles sin control de rol	Ley 20.584 art. 13; DS 41 art. 9
INC-09	Borrado físico de información clínica	Ley 20.584 art. 13 (15 años); DS 41 arts. 11 y 12
INC-11	Dependencias vulnerables	Ley 19.628 art. 11; Ley 17.336 arts. 78 y 79
INC-13	Descarga sin auditoría	DS 41 art. 9; RF-5.1
INC-14	Auditoría escribible desde el cliente	DS 41 art. 9; Ley 21.663 art. 9
INC-05, 06, 08, 10, 12, 15, 16	Endurecimiento, mensajes de error, sesión en el navegador, política de contraseñas y manejo de documentos	DS 41 art. 8; Ley 19.628 art. 11; Ley 20.584 art. 13 a); RF-4.3 y RF-4.4

Sobre INC-09 tomamos una decisión distinta a la de la EV1. El borrado físico no bloquea el uso del sistema, pero una ficha clínica eliminada sin acta antes de 15 años no se puede recuperar y deja al prestador fuera de los artículos 11 y 12 del DS 41; por eso lo

clasificamos como grave. También informamos los controles que sí funcionan: el login usa consultas parametrizadas, /usuarios rechaza con 403 a un paciente, la descarga limita al paciente a sus propios documentos y la carga de archivos limita el tamaño a 10 MB.

«[Pendiente: ajustar esta tabla con los incidentes confirmados en la ejecución y los hallazgos de SonarQube. Responsable: Giannina Guerrero]»

6.5 Lectura ética

La parte legal indica qué se puede sancionar. La parte ética parte de algo más simple: en Cuidarte+ las personas afectadas son pacientes, muchos de ellos adultos mayores, y un examen filtrado no se puede deshacer. Con esa idea definimos cuatro criterios de trabajo.

El primero es usar solo datos sintéticos, sin RUT ni datos reales, aunque el ambiente sea local. El segundo es reportar todo lo encontrado, incluido lo incómodo, como la tensión de RB-3 con la Ley 20.584; ocultar un hallazgo para que el informe se vea mejor sería faltar a la responsabilidad que asumimos como equipo de calidad. El tercero es no probar fuera del alcance: OWASP ZAP, Burp Suite, Nikto, SQLMap y John the Ripper se usan solo contra nuestra instalación en Docker, porque usarlos contra un sistema ajeno sin autorización es la conducta que sanciona la Ley 21.459. El cuarto es no minimizar el impacto en las personas mayores: un mensaje técnico como el de INC-06 o un botón que no abre el documento como en INC-12 puede dejar a un paciente sin acceso a sus resultados, lo que afecta un derecho que la Ley 20.584 le reconoce.

6.6 Dictamen

Dictamen: NO CERTIFICADO (provisional).

Mientras INC-01 siga abierto el sistema no puede certificarse. El criterio de aceptación de seguridad del ERS exige pruebas de penetración sin hallazgos críticos, y un software con defectos críticos abiertos no se certifica. A esto se suman incidentes graves que afectan directamente la confidencialidad de la ficha clínica (INC-02, INC-03, INC-07 e INC-13). Para pasar a Certificado con reservas se necesitaría, como mínimo, cerrar INC-01, INC-02 e INC-07 y presentar un plan con fechas para el resto de los incidentes graves.

«[Pendiente: confirmar el dictamen con los números finales de la sección 5.1. Responsable: Giannina Guerrero]»

6.7 Recomendaciones

6. **Hash de contraseñas con bcrypt.** Aplicarlo en el registro y en el login, cambiar las contraseñas semilla y exigir 12 caracteres con complejidad (INC-01, INC-10). Base: Ley 19.628 art. 11 y ERS §2.4.

7. **Rotar el secreto JWT e implementar logout.** Sacar el secreto del README y del .env versionado y agregar revocación de tokens (INC-02, INC-03, RF-1.2).
8. **Agregar control de rol en /roles** y revisar el resto de las rutas de administración (INC-07). Base: Ley 20.584 art. 13.
9. **Auditar lecturas y descargas** con quién, cuándo y qué recurso, y cerrar POST /auditoria a los clientes (INC-13, INC-14). Base: DS 41 art. 9.
10. **Usar baja lógica en lugar de borrado físico,** con conservación por 15 años y eliminación con acta (INC-09). Base: Ley 20.584 art. 13 y DS 41 arts. 11 y 12.
11. **Revisar RB-3 y RB-2 con el cliente:** acceso del médico a sus pacientes y acceso de emergencia registrado (OC-01). Base: Ley 20.584 arts. 13 y 15 b).
12. **Quitar el retraso artificial de 5 segundos** y volver a medir sin él (INC-04).
13. **Preparar el sistema para la Ley 21.719 antes del 01-12-2026:** cifrado en reposo, procedimiento de reporte de vulneraciones y prueba periódica de restauración de respaldos.
14. **Mostrar errores genéricos al usuario y dejar el detalle técnico solo en el servidor** (INC-06, NFR-SEG-6), para que el centro pueda cumplir la alerta de tres horas de la Ley 21.663.
15. **Actualizar dependencias y revisar licencias** (INC-11), y proteger con autenticación la ruta de documentos (INC-16).

7. Conclusiones

Con la matriz reconstruida, el diseño de pruebas de Cuidarte+ cubre el 100 % de los requisitos del ERS B, frente a cerca del 35 % de la EV1. La revisión del código y la ejecución exploratoria de la EV1 ya muestran que el sistema no está listo para producción: guarda contraseñas en texto plano, no permite cerrar sesión de forma segura, no audita las descargas de documentos clínicos y borra información que la ley obliga a conservar.

El cambio más importante respecto de la EV1 está en la lectura normativa. Al poner la Ley 20.584 y el reglamento de fichas clínicas en el centro, varios hallazgos que antes parecían solo técnicos pasan a ser incumplimientos concretos para el centro de salud, y aparece una tensión en el propio ERS (RB-3) que conviene resolver con el cliente antes de corregir el código.

«[Pendiente: completar las conclusiones con los resultados de la ejecución, el resultado de SonarQube y el dictamen final. Responsable: Giannina Guerrero]»

8. Referencias

Chile. Ley N° 20.584, regula los derechos y deberes que tienen las personas en relación con acciones vinculadas a su atención en salud. Biblioteca del Congreso Nacional, LeyChile, idNorma 1039348.

Chile. Ley N° 21.668, modifica la Ley N° 20.584 con el fin de establecer la interoperabilidad de las fichas clínicas. Diario Oficial, 28 de mayo de 2024.

Chile, Ministerio de Salud. Decreto N° 41 de 2012, aprueba reglamento sobre fichas clínicas. LeyChile, idNorma 1046753.

Chile, Ministerio de Salud. DFL N° 1 de 2005, fija texto refundido, coordinado y sistematizado del DL 2.763 de 1979 y de las leyes 18.933 y 18.469 (arts. 141 y 173). LeyChile, idNorma 249177.

Chile. Ley N° 19.628, sobre protección de la vida privada. LeyChile, idNorma 141599.

Chile. Ley N° 21.719, regula la protección y el tratamiento de los datos personales y crea la Agencia de Protección de Datos Personales. Diario Oficial, 13 de diciembre de 2024.

Chile. Ley N° 21.663, Ley Marco de Ciberseguridad. LeyChile, idNorma 1202434.

Chile. Ley N° 21.459, establece normas sobre delitos informáticos. 20 de junio de 2022.

Chile. Ley N° 17.336, sobre propiedad intelectual. 2 de octubre de 1970.

Gobierno de Chile. Manual de Accesibilidad Web.

ISO/IEC 25010. Systems and software Quality Requirements and Evaluation (SQuaRE): modelos de calidad.

OWASP Foundation. OWASP Top 10: riesgos de seguridad en aplicaciones web.

DuocUC. EP1_ISY1102_Estudiante_ERS_B: especificación de requerimientos de software del sistema Cuidarte+, versión 1.1.

DuocUC. Evaluación Parcial N° 3 ISY1102: instrucciones, pauta de evaluación y formato de informe.

Araya, A., Barra, N., Guerrero, G. y Tropan, S. Repositorio Barrolas/cuidarte-mas, rama main, commit 7503d1b.

Anexo A. Correcciones respecto de la EV1

La EP3 pide retomar la primera evaluación con los ajustes surgidos de la retroalimentación del docente, que fue entregada de forma presencial. La tabla resume los cambios aplicados en este informe.

Tabla 31. Correcciones aplicadas

N°	Dónde (EV1)	Antes	Ahora (EP3)	Sección
A1	§5.1 Matriz	11 filas, 14 de 40 códigos; 21 sin caso	40 de 40 códigos con caso (CP-01 a CP-23)	4.1
A2	§5.1 Cobertura	Se marcaba Cubierto con solo diseñar el caso	Se separan cobertura de diseño y resultado de ejecución	3.3, 4.1, 5
A3	§5.2 Brechas	RF-2, RF-4.2, NFR-PERF-2 y 3, NFR-SEG-1 y 7, NFR-DIS-1 postergados	Cada uno con caso: CP-08 a CP-10, CP-13, CP-14, CP-18, CP-19 y CP-21	4.1, 4.2
A4	CP-03	RF-5.1 probado solo con la eliminación	Se agregan la subida y la descarga de documentos	4.3
B1	§2.3 Ley 19.628	Se citaba el art. 22 y "derechos del paciente sobre su ficha"	Arts. 2 g), 7, 10, 11 y 23; los derechos sobre la ficha pasan a la Ley 20.584	6.2
B2	§2.3 texto suelto	Código Sanitario, Ley 20.584, decretos y normas técnicas sin artículos	Ley 20.584, Ley 21.668, DS 41 y urgencia (DFL 1) con artículos y casos; se retira el Código Sanitario	6.2
B3	§2.3 Ley 21.719	Tratada como vigente	Vigente desde el 01-12-2026; hoy la base es la Ley 19.628	2.3, 6.2
B4	§2.3, §5.2 y §6	"art. 35 de la Ley 21.719"	Art. 35 de la Ley 19.628 en el texto que introduce la Ley 21.719	6.2
B5	§2.3 Ley 21.663	Art. 36 y "eleva el estándar de la plataforma"	Arts. 4, 9 y 27; la obligada es la institución de salud	6.2
B6	§2.3 DS 181 y §6	Título Cuarto del DS 181 como base de la integridad documental	La integridad se funda en la Ley 20.584 art. 12 y el DS 41 art. 8	2.3, 6.2
B7	§2.2 y CP-02	RB-3 solo como requisito funcional	Se agrega la observación de cumplimiento OC-01	6.3
C1	Nombre del caso	El README del repositorio dice "Caso A"	Caso B: Sistema de exámenes médicos Cuidarte+	Portada, 1.1
D1	§1.3	Títulos de objetivos vacíos	Objetivo general y específicos redactados	1.3
D2	§3.4 y §5.1	Bloque "TIPOS DE PRUEBAS…" repetido	Eliminado; los tipos se desarrollan en 3.2	3.2
D3	§3.1, §3.4, CP-05	Jest y k6	Herramientas realmente usadas; JMeter para carga	3.4

Anexo B. Evidencias de la EV1 reutilizadas

Las evidencias siguientes están en la carpeta docs/EV1 Entrega del repositorio y se citan como línea base en la sección 5.1. Las evidencias del ciclo 2 de la EP3 se agregarán en una carpeta nueva de evidencias de la EV2.

Tabla 32. Evidencias de la EV1

Archivo	Contenido	Casos
Informe_Hallazgos_CuidartePlus.md y .pdf	Hallazgos HALL-01 a HALL-05 y controles que funcionaron (7 y 8 de septiembre de 2026)	CP-01, 02, 04, 05, 06
Informe_OWASP_ZAP_CuidartePlus.md y Anexos/OWASP_ZAP_*	Escaneo baseline sin sesión del frontend y de la API (PDF, HTML y JSON)	CP-04
Anexos/jmeter: CuidartePlus_CP05.jmx, results_cp05.jtl y html_report	Plan y resultados de JMeter con el retraso activo	CP-05

«[Pendiente: capturas del ciclo 2 de la EP3 (todos los responsables)]»